

บทที่ 1: ภาพรวมของความมั่นคงปลอดภัย (Overview of Security)



1.2 ความมั่นคงปลอดภัยสารสนเทศ และความมั่นคงปลอดภัยของระบบสารสนเทศ

1.2.1 ความหมายของความมั่นคงปลอดภัยสารสนเทศ (Information Security)

ความมั่นคงปลอดภัยสารสนเทศ

หมายถึง กระบวนการ มาตรการ และเทคโนโลยีที่ใช้ในการ ปกป้องข้อมูล (Data) หรือ สารสนเทศ (Information) จากการเข้าถึง การใช้ การเปิดเผย การเปลี่ยนแปลง การทำลาย หรือการรบกวนโดยไม่ได้รับอนุญาต

กล่าวอีกนัยหนึ่ง คือการ “รักษาความลับ ความถูกต้อง และความพร้อมใช้งาน” ของข้อมูล ซึ่งเรียกรวมกันว่า หลักการ CIA Triad

องค์ประกอบ	ความหมาย	ตัวอย่างเทคโนโลยี
Confidentiality (การรักษาความลับ)	จำกัดการเข้าถึงข้อมูลเฉพาะผู้มีสิทธิ์เท่านั้น	การเข้ารหัสข้อมูล (Encryption), การควบคุมสิทธิ์ (Access Control)
Integrity (ความถูกต้องครบถ้วน)	ป้องกันการแก้ไขหรือดัดแปลงข้อมูลโดยไม่ได้รับอนุญาต	การตรวจสอบค่าแฮช (Hash), Digital Signature
Availability (ความพร้อมใช้งาน)	ทำให้ข้อมูลและระบบพร้อมใช้งานได้ทุกเมื่อที่ต้องการ	ระบบสำรอง (Backup), ระบบทำงานซ้ำซ้อน (Redundancy)

ตัวอย่างเชิงเทคโนโลยี

- ระบบ Data Loss Prevention (DLP) ใช้ตรวจจับและป้องกันไม่ให้ข้อมูลสำคัญรั่วไหลออกนอกองค์กร
- การใช้ Multi-Factor Authentication (MFA) เพื่อเพิ่มความปลอดภัยในการเข้าถึงข้อมูล
- การเข้ารหัสแบบ AES (Advanced Encryption Standard) เพื่อรักษาความลับของข้อมูล

เป้าหมายของ Information Security

คือการสร้างสมดุลระหว่าง “ความปลอดภัย (Security)” และ “ความสามารถในการใช้งาน (Usability)” เพื่อให้ผู้ใช้สามารถเข้าถึงข้อมูลได้อย่างปลอดภัยและมีประสิทธิภาพ

1.2.2 ความมั่นคงปลอดภัยของระบบสารสนเทศ (Information Systems Security)

ระบบสารสนเทศ (Information System)

หมายถึง ระบบที่ประกอบด้วยองค์ประกอบหลัก 4 ส่วน ได้แก่

- ฮาร์ดแวร์ (Hardware) – เช่น เซิร์ฟเวอร์, เครื่องลูกข่าย, อุปกรณ์เครือข่าย
- ซอฟต์แวร์ (Software) – ระบบปฏิบัติการ, โปรแกรมประยุกต์, ระบบฐานข้อมูล
- บุคลากร (People) – ผู้ใช้งาน, ผู้ดูแลระบบ, ผู้บริหาร
- กระบวนการและนโยบาย (Processes / Policies) – ขั้นตอน วิธีปฏิบัติ และกฎระเบียบในการรักษาความปลอดภัย

ความมั่นคงปลอดภัยของระบบสารสนเทศ (Information Systems Security)

จึงหมายถึงการปกป้อง “ระบบ” ที่ใช้จัดเก็บ ประมวลผล และส่งต่อข้อมูลเหล่านั้นให้ปลอดภัยจากการโจมตีหรือความเสียหาย ซึ่งต่างจาก Information Security ที่เน้นเฉพาะ “ข้อมูล”

กล่าวได้ว่า

- Information Security เน้นปกป้อง “ข้อมูล”
- Information Systems Security เน้นปกป้อง “ระบบ” ที่เก็บและประมวลผลข้อมูล

ตัวอย่างเปรียบเทียบ

มุมมอง	Information Security	Information Systems Security
ขอบเขตการปกป้อง	ข้อมูล (Data / Information)	ระบบที่จัดเก็บและประมวลผลข้อมูล (System / Infrastructure)
จุดเน้น	การป้องกันการรั่วไหล การแก้ไขข้อมูล	การป้องกันการโจมตี การบุกรุก การล่มของระบบ
เทคโนโลยีหลัก	Encryption, DLP, Access Control	Firewall, IDS/IPS, Patch Management
ตัวอย่างการใช้งาน	การเข้ารหัสไฟล์, การควบคุมสิทธิ์ การกำหนดค่าอุปกรณ์เครือข่ายอย่างปลอดภัย, การผู้ใช้งาน	สำรองระบบ

1.2.3 หลักการพื้นฐานของการรักษาความมั่นคงปลอดภัยระบบสารสนเทศ

เพื่อให้ระบบสารสนเทศมีความมั่นคงปลอดภัยในทุกระดับ องค์กรควรดำเนินการภายใต้แนวคิดหลักดังต่อไปนี้

- 1. **Risk-Based Approach (แนวทางบนพื้นฐานความเสี่ยง)**
วิเคราะห์และประเมินความเสี่ยงของข้อมูลและระบบ เพื่อจัดลำดับความสำคัญของการป้องกัน
- 2. **Defense in Depth (การป้องกันแบบหลายชั้น)**
ใช้การควบคุมหลายระดับ เช่น Firewall + Antivirus + Monitoring + Awareness Training
- 3. **Secure Baseline Configuration (มาตรฐานความปลอดภัยพื้นฐาน)**
กำหนดค่าระบบให้ปลอดภัยตั้งแต่เริ่มต้น เช่น การปิดพอร์ตที่ไม่จำเป็น การตั้งรหัสผ่านซับซ้อน
- 4. **Continuous Monitoring (การเฝ้าระวังอย่างต่อเนื่อง)**
ใช้ระบบตรวจจับเหตุการณ์ เช่น SIEM (Security Information and Event Management) เพื่อตรวจสอบการโจมตีแบบเรียลไทม์

1.2.4 สรุปแนวคิดสำคัญ

- **Information Security** → เน้น “ข้อมูล” ให้ปลอดภัย
- **Information Systems Security** → เน้น “ระบบ” ที่เก็บและประมวลผลข้อมูลให้ปลอดภัย
- ทั้งสองแนวคิดทำงานร่วมกัน เพื่อสร้างสภาพแวดล้อมด้านความมั่นคงปลอดภัยที่สมบูรณ์แบบ
- นักศึกษาควรเข้าใจว่า “การรักษาความปลอดภัยข้อมูล” เป็นส่วนหนึ่งของ “การรักษาความปลอดภัยระบบสารสนเทศ”

1.3 หลักการ CIA Triad — Confidentiality, Integrity, Availability

หลักการ **CIA Triad** ถือเป็นรากฐานสำคัญที่สุดของศาสตร์ด้าน **Information Security (ความมั่นคงปลอดภัยสารสนเทศ)** ที่ใช้กำหนดแนวทางในการปกป้องข้อมูลและระบบสารสนเทศขององค์กรให้มีความปลอดภัยครบทุกมิติ ไม่ว่าจะเป็นการป้องกันการเข้าถึงโดยไม่ได้รับอนุญาต การรักษาความถูกต้องของข้อมูล และการทำให้ระบบพร้อมใช้งานอยู่เสมอ ทั้งสามองค์ประกอบนี้สัมพันธ์กันและต้องดำเนินการควบคู่กัน เพื่อสร้างความเชื่อมั่นว่าข้อมูลจะยังคงมี **ความลับ (Confidentiality)** **ความถูกต้อง (Integrity)** และ **ความพร้อมใช้งาน (Availability)** ตลอดวงจรชีวิตของข้อมูล

หากองค์ประกอบใดองค์ประกอบหนึ่งล้มเหลว ย่อมส่งผลกระทบต่อประสิทธิภาพและความน่าเชื่อถือของระบบโดยรวม เช่น ข้อมูลที่ถูกเข้ารหัสเพื่อความปลอดภัยแต่ไม่สามารถเข้าถึงได้ ก็ไม่ถือว่าปลอดภัยอย่างแท้จริง ดังนั้น CIA Triad จึงเป็นทั้งกรอบแนวคิดและหลักปฏิบัติที่ใช้ในการออกแบบระบบรักษาความปลอดภัยสมัยใหม่ทุกประเภท

1.3.1. ความหมายของแต่ละองค์ประกอบใน CIA Triad

องค์ประกอบ	ความหมาย	ตัวอย่างเทคโนโลยี / มาตรการ
C – Confidentiality (การรักษาความลับ)	การป้องกันไม่ให้ข้อมูลถูกเปิดเผยหรือเข้าถึงโดยบุคคลที่ไม่มีสิทธิ์ เพื่อให้ข้อมูลถูกใช้งานเฉพาะผู้ที่ได้รับอนุญาตเท่านั้น	การเข้ารหัสข้อมูล (Encryption), การควบคุมสิทธิ์การเข้าถึง (Access Control), การตรวจสอบตัวตน (Authentication), การใช้ Multi-Factor Authentication (MFA)

องค์ประกอบ	ความหมาย	ตัวอย่างเทคโนโลยี / มาตรการ
I – Integrity (ความถูกต้องครบถ้วนของข้อมูล)	การป้องกันไม่ให้ข้อมูลถูกแก้ไข ดัดแปลง หรือถูกทำลายโดยไม่ได้รับอนุญาต รวมถึงการตรวจสอบให้แน่ใจว่าข้อมูลที่รับหรือส่งมามีความถูกต้องตรงกับต้นฉบับ	การตรวจสอบค่าแฮช (Hashing), การใช้ลายเซ็นดิจิทัล (Digital Signature), การควบคุมเวอร์ชันของเอกสาร (Version Control), การตรวจสอบการเปลี่ยนแปลง (Audit Trail)
A – Availability (ความพร้อมใช้งาน)	การทำให้ข้อมูลและระบบสามารถเข้าถึงและใช้งานได้ตลอดเวลา สำหรับผู้ที่ได้รับอนุญาต โดยไม่ถูกรบกวนจากเหตุขัดข้องหรือการโจมตี	ระบบสำรองข้อมูล (Backup System), ระบบซ้ำซ้อน (Redundancy), การวางแผนกู้คืนระบบ (Disaster Recovery Planning), การป้องกัน DDoS

1.3.2. การอธิบายเชิงเทคนิคของแต่ละองค์ประกอบ

Confidentiality (การรักษาความลับ)

เป้าหมายหลักของ Confidentiality คือ “การป้องกันการเข้าถึงข้อมูล” โดยใช้กลไกทางเทคโนโลยี เช่น

- **การเข้ารหัส (Encryption):** แปลงข้อมูลให้อยู่ในรูปแบบที่ไม่สามารถอ่านได้โดยผู้ไม่มีสิทธิ์ เช่น การใช้มาตรฐาน AES-256
- **การควบคุมสิทธิ์ (Access Control):** กำหนดสิทธิ์ผู้ใช้งานระบบ **Role-Based Access Control (RBAC)** เพื่อให้เข้าถึงข้อมูลได้ตามหน้าที่เท่านั้น
- **การตรวจสอบสิทธิ์หลายชั้น (MFA):** เพิ่มความปลอดภัยในการยืนยันตัวตน เช่น รหัสผ่าน + OTP + ลายนิ้วมือ

Integrity (ความถูกต้องของข้อมูล)

Integrity ทำให้มั่นใจได้ว่าข้อมูลจะไม่ถูกเปลี่ยนแปลงโดยไม่ได้รับอนุญาต

- **การใช้ Hash Function:** เช่น SHA-256 เพื่อสร้างค่าตรวจสอบ (Checksum) สำหรับยืนยันว่าข้อมูลไม่ถูกแก้ไข
- **Digital Signature:** ใช้คู่กุญแจสาธารณะ-ส่วนตัว ในการรับรองความถูกต้องของผู้ส่งและความสมบูรณ์ของข้อมูล
- **ระบบตรวจสอบการเปลี่ยนแปลง (File Integrity Monitoring – FIM):** ตรวจจับการเปลี่ยนแปลงของไฟล์ระบบที่สำคัญแบบเรียลไทม์

Availability (ความพร้อมใช้งาน)

Availability ทำให้ผู้ใช้ที่ได้รับสิทธิ์สามารถเข้าถึงระบบได้ตลอดเวลา

- **การสำรองข้อมูล (Backup & Restore):** ใช้แนวทาง **3–2–1 Backup** (3 ชุดข้อมูล, 2 ลือ, 1 ชุดอยู่นอกสถานที่)
- **ระบบซ้ำซ้อน (Redundancy):** เช่น RAID สำหรับจัดเก็บข้อมูลแบบสำรอง และการใช้ระบบคลัสเตอร์ (Failover Cluster)
- **Disaster Recovery (DR) / Business Continuity (BC):** วางแผนกู้คืนระบบและการทำงานขององค์กรให้กลับมาภายในระยะเวลา RTO/RPO ที่กำหนด

1.3.3. การนำ CIA Triad ไปประยุกต์ใช้ในระบบจริง

ในองค์กรสมัยใหม่ หลักการ CIA ถูกนำไปใช้ในทุกระดับของโครงสร้างเทคโนโลยี เช่น

- **DLP (Data Loss Prevention):** ป้องกันการรั่วไหลของข้อมูลสำคัญ โดยตรวจสอบและบล็อกการส่งข้อมูลออกจากเครือข่าย (เน้นด้าน Confidentiality)
- **MFA (Multi-Factor Authentication):** เพิ่มชั้นความปลอดภัยในการยืนยันตัวตน (Confidentiality + Integrity)
- **RBAC (Role-Based Access Control):** จำกัดสิทธิ์ผู้ใช้งานให้เข้าถึงข้อมูลเฉพาะที่จำเป็น (Confidentiality)
- **Hash Check:** ตรวจสอบความถูกต้องของไฟล์ซอฟต์แวร์หรือฐานข้อมูลหลังการอัปเดต (Integrity)

- **DR/BC Planning:** เตรียมระบบสำรองและแผนกู้คืนเพื่อให้บริการต่อเนื่องในกรณีฉุกเฉิน (Availability)

1.3.4. สรุปแนวคิด

หลักการ **CIA Triad** เป็นแกนกลางของการรักษาความมั่นคงปลอดภัยสารสนเทศทุกระบบ

- **Confidentiality** ช่วยให้อข้อมูลคงความลับ
- **Integrity** ทำให้มั่นใจว่าข้อมูลไม่ถูกบิดเบือน
- **Availability** ทำให้ข้อมูลและระบบพร้อมใช้งานเสมอ

ทั้งสามองค์ประกอบนี้ไม่ได้แยกจากกัน แต่ทำงานร่วมกันเพื่อสร้างสภาพแวดล้อมที่ปลอดภัย มีความเชื่อถือได้ และรองรับการดำเนินงานอย่างต่อเนื่องในทุกสถานการณ์ นักศึกษาวิทยาการคอมพิวเตอร์ควรเข้าใจหลักการ CIA Triad เป็นพื้นฐาน ก่อนต่อยอดสู่การออกแบบและบริหารระบบความปลอดภัยไซเบอร์ในระดับองค์กร

1.4 โมเดล AAA — Authentication, Authorization, Accounting

หนึ่งในกลไกสำคัญที่สุดของระบบความมั่นคงปลอดภัยสารสนเทศ คือ **โมเดล AAA (Authentication, Authorization, Accounting)** ซึ่งทำหน้าที่เป็นรากฐานของการควบคุมการเข้าถึง (Access Control) ภายในระบบสารสนเทศและเครือข่ายคอมพิวเตอร์ โมเดล AAA ใช้ในการยืนยันตัวตนของผู้ใช้ (Authentication) กำหนดสิทธิ์ในการเข้าถึง (Authorization) และบันทึกกิจกรรมการใช้งานทั้งหมด (Accounting) เพื่อให้มั่นใจได้ว่าทุกการกระทำในระบบสามารถตรวจสอบได้ภายหลัง

แนวคิด AAA Model ถูกใช้เป็นโครงสร้างหลักในระบบ **Identity and Access Management (IAM)** ซึ่งเป็นเทคโนโลยีและแนวปฏิบัติที่ใช้บริหารวงจรชีวิตของบัญชีผู้ใช้ (User Identity Lifecycle) ในองค์กรสมัยใหม่ ไม่ว่าจะเป็นระบบเครือข่ายท้องถิ่น (LAN), ระบบคลาวด์ (Cloud Infrastructure) หรือระบบเครือข่ายภาคีรัฐและเอกชน AAA จึงเป็นทั้งกลไกทางเทคนิคและกรอบการกำกับดูแลที่ช่วยให้องค์กรสามารถรักษาความมั่นคงปลอดภัยได้อย่างต่อเนื่อง

1.4.1. องค์ประกอบของโมเดล AAA

Authentication (การยืนยันตัวตน)

Authentication คือกระบวนการตรวจสอบว่า “ผู้ที่พยายามเข้าสู่ระบบคือผู้ที่อ้างว่าเป็นจริงหรือไม่” โดยใช้ข้อมูลหรือปัจจัยในการพิสูจน์ตัวตน ซึ่งแบ่งได้เป็น 5 ประเภทหลักคือ

1. **Something you know** — สิ่งที่คุณรู้ เช่น รหัสผ่าน (Password) หรือรหัส PIN
2. **Something you have** — สิ่งที่คุณมี เช่น โทเคน (Token), บัตรสมาร์ทการ์ด (Smart Card), หรือโทรศัพท์มือถือ
3. **Something you are** — สิ่งที่คุณเป็น เช่น ลายนิ้วมือ (Fingerprint), ใบหน้า (Face Recognition), ม่านตา (Iris)
4. **Something you do** — พฤติกรรมของผู้ใช้ เช่น รูปแบบการพิมพ์ การเคลื่อนไหวของเมาส์
5. **Somewhere you are** — ตำแหน่งหรือสถานที่ของผู้ใช้ เช่น ตรวจสอบ IP Address หรือพิกัด GPS

เทคโนโลยีที่นิยมใช้ เช่น

- **Multi-Factor Authentication (MFA)** — การรวมหลายปัจจัยเข้าด้วยกัน เช่น รหัสผ่าน + รหัส OTP
- **One-Time Password (OTP)** — รหัสผ่านใช้ครั้งเดียว เพิ่มความปลอดภัยจากการโจมตีแบบ Replay Attack
- **Single Sign-On (SSO)** — ระบบที่ให้คุณใช้เข้าสู่ระบบเพียงครั้งเดียวเพื่อเข้าถึงหลายบริการภายในองค์กร

กระบวนการ Authentication ที่ดีช่วยลดโอกาสในการเข้าถึงระบบโดยผู้ไม่หวังดี และถือเป็นด่านแรกของการป้องกันการโจมตีไซเบอร์ เช่น การขโมยบัญชีผู้ใช้หรือการเจาะระบบผ่านช่องทางการยืนยันตัวตนที่อ่อนแอ

Authorization (การกำหนดสิทธิ์การเข้าถึง)

Authorization เป็นขั้นตอนต่อจากการยืนยันตัวตน เมื่อระบบทราบแล้วว่า “คุณคือใคร” ระบบจะต้องกำหนดต่อไปว่า “คุณสามารถทำอะไรได้บ้าง” การกำหนดสิทธิ์อย่างเหมาะสมช่วยลดความเสี่ยงจากการเข้าถึงข้อมูลที่ไม่ควรเข้าถึง

ไม่จำเป็นและป้องกันการยกระดับสิทธิ์โดยไม่ได้รับอนุญาต

แนวทางการควบคุมสิทธิ์ที่ใช้กันทั่วไป ได้แก่

- **RBAC (Role-Based Access Control):** การกำหนดสิทธิ์ตาม “บทบาทของผู้ใช้” เช่น พนักงานทั่วไป, ผู้จัดการ, ผู้ดูแลระบบ
- **ABAC (Attribute-Based Access Control):** ใช้ “คุณลักษณะ (Attributes)” ของผู้ใช้ เช่น หน่วยงาน ตำแหน่ง สถานที่ และเวลา เพื่อสร้างเงื่อนไขการเข้าถึงแบบยืดหยุ่น
- **Separation of Duties (SoD):** หลักการแบ่งแยกหน้าที่ เพื่อลดความเสี่ยงจากการที่บุคคลใดบุคคลหนึ่งมีสิทธิ์มากเกินไป เช่น คนเดียวไม่สามารถทั้งสร้างและอนุมัติธุรกรรมทางการเงินได้

ระบบ Authorization ที่ดีควรสนับสนุนการตรวจสอบสิทธิ์แบบอัตโนมัติ การทบทวนสิทธิ์เป็นระยะ และใช้แนวทาง **Least Privilege** ซึ่งหมายถึง การให้สิทธิ์น้อยที่สุดเท่าที่จำเป็นต่อการทำงาน

Accounting (การบันทึกและตรวจสอบกิจกรรม)

Accounting หรือบางครั้งเรียกว่า **Auditing** คือกระบวนการบันทึกและติดตามกิจกรรมของผู้ใช้ภายในระบบ เพื่อให้สามารถตรวจสอบย้อนหลัง (Traceability) ได้ว่าใครทำอะไร ที่ไหน และเมื่อใด

เทคโนโลยีที่สำคัญในส่วนนี้ ได้แก่

- **Logging System:** ระบบบันทึกเหตุการณ์ของระบบปฏิบัติการ เครือข่าย หรือแอปพลิเคชัน
- **SIEM (Security Information and Event Management):** ระบบรวมศูนย์ข้อมูล Log จากหลายแหล่งเพื่อวิเคราะห์หาพฤติกรรมที่ผิดปกติหรือเหตุการณ์ความปลอดภัย
- **Time Synchronization (NTP – Network Time Protocol):** การปรับเวลาให้ตรงกันในทุกระบบ เพื่อให้การวิเคราะห์ Log มีความถูกต้องและสามารถเชื่อมโยงเหตุการณ์ได้อย่างแม่นยำ

Accounting ไม่เพียงแต่ช่วยในการสอบสวนเหตุการณ์ความปลอดภัย แต่ยังสนับสนุนการปฏิบัติตามข้อกำหนดด้านกฎหมาย เช่น GDPR, PDPA และ ISO/IEC 27001

1.4.2. ภัยคุกคามที่เกี่ยวข้องและแนวทางลดความเสี่ยง

ประเภทภัยคุกคาม	คำอธิบาย	แนวทางลดความเสี่ยง
Phishing	การหลอกลวงให้ผู้ใช้เปิดเผยข้อมูลยืนยันตัวตน เช่น Username/Password ผ่านอีเมลหรือเว็บไซต์ปลอม	ใช้ MFA เพื่อลดผลกระทบ, ฝึกอบรมผู้ใช้ (Awareness Training), ใช้ระบบกรองอีเมล
Privilege Escalation	การยกระดับสิทธิ์โดยไม่ได้รับอนุญาต เช่น การเจาะช่องโหว่เพื่อเปลี่ยนจากผู้ใช้ธรรมดาเป็นผู้ดูแลระบบ	ใช้ RBAC และ Least Privilege, ทำ Patch Management อย่างสม่ำเสมอ, ตรวจสอบสิทธิ์เป็นระยะ
Log Tampering	การลบหรือแก้ไขข้อมูล Log เพื่อปกปิดร่องรอยการโจมตี	ใช้ระบบ Log Integrity Check, บันทึก Log ลง WORM Storage (Write Once Read Many), รวมศูนย์ Log ด้วย SIEM และกำหนดสิทธิ์เข้าถึงเฉพาะผู้ดูแลระบบ

1.4.3. สรุปแนวคิด

โมเดล **AAA (Authentication, Authorization, Accounting)** เป็นองค์ประกอบหลักของการรักษาความมั่นคงปลอดภัยเชิงระบบ ซึ่งทำงานเชื่อมโยงกันเป็นวงจร

- **Authentication** เป็นด่านแรกที่ตรวจสอบว่า “ใครคือผู้ใช้”
- **Authorization** กำหนดว่า “ผู้ใช้นั้นสามารถทำอะไรได้บ้าง”
- **Accounting** ทำหน้าที่บันทึก “สิ่งที่ผู้ใช้ได้ทำไปแล้ว” เพื่อความโปร่งใสและตรวจสอบได้

ทั้งสามกระบวนการนี้เป็นรากฐานของเทคโนโลยีด้าน **Identity and Access Management (IAM)** และระบบรักษาความปลอดภัยในองค์กรสมัยใหม่ การนำ AAA มาประยุกต์ใช้อย่างถูกต้องจะช่วยให้องค์กรสามารถควบคุมการเข้าถึง ป้องกันภัยคุกคาม และตรวจสอบเหตุการณ์ความปลอดภัยได้อย่างมีประสิทธิภาพ ทำให้ระบบสารสนเทศมีความน่าเชื่อถือ ปลอดภัย และเป็นไปตามมาตรฐานสากล

1.5 ภัยคุกคามและผู้ก่อภัยคุกคาม (Security Threats and Threat Actors)

ในยุคดิจิทัลที่ข้อมูลและเทคโนโลยีเป็นทรัพยากรสำคัญขององค์กร “ภัยคุกคามทางไซเบอร์ (Security Threats)” ได้กลายเป็นปัจจัยหลักที่ส่งผลกระทบต่อความมั่นคงปลอดภัยของระบบสารสนเทศ ไม่ว่าจะเป็นการโจมตีจากซอฟต์แวร์ที่เป็นอันตราย การเข้าถึงโดยไม่ได้รับอนุญาต ความผิดพลาดของระบบ หรือแม้กระทั่งการหลอกลวงผู้ใช้งานโดยอาศัยจิตวิทยา

ภัยคุกคามไม่ได้เกิดจากเทคโนโลยีเพียงอย่างเดียว แต่เกิดจาก **สามองค์ประกอบหลักของระบบสารสนเทศ** ได้แก่ **คน (People)**, **กระบวนการ (Process)**, และ **เทคโนโลยี (Technology)** ซึ่งเมื่อขาดการควบคุมหรือมีจุดอ่อน อาจเปิดช่องทางให้ผู้ไม่หวังดี (Threat Actors) เข้ามาโจมตีได้ การเข้าใจลักษณะของภัยคุกคามและผู้ก่อภัยคุกคามจึงเป็นพื้นฐานของการวิเคราะห์ความเสี่ยง (Risk Assessment) และการวางแผนป้องกันเชิงรุก (Proactive Security Planning)

1.5.1. ประเภทภัยคุกคามหลัก (Major Categories of Security Threats)

ภัยคุกคามสามารถจำแนกได้หลายรูปแบบ โดยมีสี่กลุ่มหลักที่พบบ่อยในงานด้านความมั่นคงปลอดภัยสารสนเทศ ได้แก่

Malware (มัลแวร์)

มัลแวร์คือซอฟต์แวร์ที่ถูกออกแบบมาเพื่อทำลายระบบหรือขโมยข้อมูล แบ่งออกเป็นหลายประเภท เช่น

- Virus (ไวรัส):** แพร่กระจายโดยการแนบตัวเข้ากับไฟล์หรือโปรแกรม และทำงานเมื่อผู้ใช้เปิดไฟล์นั้น
- Worm (เวิร์ม):** แพร่กระจายผ่านเครือข่ายโดยอัตโนมัติ ไม่ต้องอาศัยการกระทำของผู้ใช้
- Trojan Horse (โทรจัน):** ซ่อนตัวอยู่ในโปรแกรมที่ดูเหมือนปลอดภัย เพื่อเปิดช่องทางให้ผู้โจมตีเข้าควบคุมระบบ
- Ransomware:** เข้ารหัสข้อมูลในเครื่องเหยื่อเพื่อเรียกค่าไถ่ เช่น WannaCry หรือ LockBit
- Rootkit:** แฝงตัวในระดับระบบปฏิบัติการเพื่อยึดสิทธิ์ผู้ดูแลระบบ (Administrator Privilege) และหลีกเลี่ยงการตรวจจับ

แนวทางป้องกัน: ใช้ระบบป้องกันมัลแวร์ (Anti-Malware), อัปเดตแพตช์ความปลอดภัยอย่างสม่ำเสมอ และจำกัดสิทธิ์ของผู้ใช้งาน

Unauthorized Access (การเข้าถึงโดยไม่ได้รับอนุญาต)

เป็นภัยคุกคามที่เกิดจากการที่บุคคลไม่ได้รับสิทธิ์เข้าถึงข้อมูลแต่สามารถฝ่าระบบควบคุมเข้าไปได้ ตัวอย่างเช่น การโจมตีแบบ **Brute Force**, **Credential Stuffing**, หรือการขโมยรหัสผ่านผ่านการ **Phishing**

แนวทางป้องกัน: ใช้ระบบ **Multi-Factor Authentication (MFA)**, เข้ารหัสข้อมูล (Encryption), และตรวจสอบ Log การเข้าถึงด้วยระบบ **SIEM (Security Information and Event Management)**

System Failure (ความล้มเหลวของระบบ)

หมายถึงความผิดพลาดของฮาร์ดแวร์ ซอฟต์แวร์ หรือระบบเครือข่ายที่ทำให้บริการไม่สามารถทำงานได้ เช่น ฮาร์ดดิสก์เสีย การจ่ายไฟไม่เสถียร หรือข้อผิดพลาดในการอัปเดตระบบ

แนวทางป้องกัน: ใช้ระบบสำรองข้อมูล (Backup), ออกแบบระบบซ้ำซ้อน (Redundancy), และมีแผน **Disaster Recovery Plan (DRP)** เพื่อกู้คืนระบบเมื่อเกิดเหตุฉุกเฉิน

Social Engineering (วิศวกรรมสังคม)

คือการโจมตีโดยใช้ “มนุษย์เป็นเป้าหมาย” ผ่านการหลอกลวงทางจิตวิทยา เช่น

- Phishing:** ส่งอีเมลหลอกลวงให้ผู้ใช้เปิดลิงก์หรือกรอกข้อมูลส่วนตัว
- Pretexting:** สร้างเรื่องสมมติหลอกลวงให้เหยื่อเปิดเผยข้อมูล
- Baiting:** ใช้สิ่งล่อ เช่น แฟลชไดรฟ์หรือไฟล์ดาวน์โหลด
- Tailgating:** แอบตามบุคคลที่มีสิทธิ์เข้าสถานที่หรือระบบ

แนวทางป้องกัน: สร้างวัฒนธรรมความตระหนักรู้ด้านความปลอดภัย (Security Awareness Training) และตรวจสอบสิทธิ์ผู้เข้าถึงอย่างเข้มงวด

1.5.2. ผู้ก่อภัยคุกคาม (Threat Actors)

“ผู้ก่อภัยคุกคาม” หมายถึง บุคคลหรือกลุ่มที่มีเจตนาหรือศักยภาพในการโจมตีระบบสารสนเทศ แต่ละกลุ่มมีแรงจูงใจ (Motivation) และระดับความสามารถ (Capability) แตกต่างกัน ดังตารางต่อไปนี้

ประเภท	ลักษณะ	ตัวอย่าง/แรงจูงใจ
White Hat	ผู้เชี่ยวชาญด้านความปลอดภัยที่ทำงานอย่างถูกกฎหมาย (Ethical Hacker)	ทดสอบระบบเพื่อหาช่องโหว่และช่วยองค์กรปรับปรุงความปลอดภัย
Black Hat	แฮ็กเกอร์ที่ละเมิดกฎหมายเพื่อผลประโยชน์ส่วนตัว	ขโมยข้อมูลส่วนบุคคล เรียกว่าได้ หรือขายข้อมูลในตลาดมืด
Gray Hat	อยู่กึ่งกลางระหว่าง White และ Black Hat	เปิดเผยช่องโหว่โดยไม่ได้รับอนุญาต เพื่อสร้างชื่อเสียง
Blue Team / Red Team / Purple Team	ทีมปฏิบัติการจำลองการโจมตีและป้องกันในองค์กร	ใช้ในการทดสอบการตอบสนองต่อภัยคุกคาม
Hacktivists	กลุ่มที่ใช้การโจมตีทางไซเบอร์เพื่อสนับสนุนอุดมการณ์ทางสังคมหรือการเมือง	โจมตีเว็บไซต์หน่วยงานรัฐหรือองค์กรที่ขัดแย้งกับอุดมการณ์
Organized Crime	กลุ่มอาชญากรรมไซเบอร์ที่มีเงินทุนและเครื่องมือขั้นสูง	โจมตีระบบการเงินหรือข้อมูลลูกค้าเพื่อผลประโยชน์ทางการเงิน
APTs (Advanced Persistent Threats)	กลุ่มผู้โจมตีที่ได้รับการสนับสนุนจากรัฐ (State-Sponsored Attackers)	การจารกรรมข้อมูล ความมั่นคงแห่งชาติ หรือความลับทางอุตสาหกรรม
Insiders	บุคลากรภายในองค์กร เช่น พนักงานหรือผู้รับจ้างที่มีสิทธิ์เข้าถึงข้อมูล	การรั่วไหลของข้อมูลภายในโดยตั้งใจหรือประมาท

1.5.3. การวิเคราะห์ผู้ก่อภัยคุกคามตาม 4 ปัจจัย (MCRO Model)

การวิเคราะห์ Threat Actors ตามกรอบ **Motivation – Capability – Resources – Opportunity** ช่วยให้นักวิเคราะห์สามารถประเมินความเสี่ยงและออกแบบมาตรการป้องกันที่เหมาะสมได้ ดังนี้

ปัจจัย	ความหมาย	ตัวอย่าง
Motivation (แรงจูงใจ)	เหตุผลที่ผู้โจมตีลงมือ เช่น เงิน ชื่อเสียง อุดมการณ์ หรือการแก้แค้น	Ransomware = แรงจูงใจทางการเงิน, Hacktivist = อุดมการณ์ทางสังคม
Capability (ความสามารถ)	ระดับทักษะทางเทคนิคและความเชี่ยวชาญของผู้โจมตี	กลุ่ม APTs มีความชำนาญสูง ใช้เครื่องมือขั้นสูงในการจารกรรมข้อมูล
Resources (ทรัพยากร)	เงินทุน เครื่องมือ บุคลากร หรือเทคโนโลยีที่ผู้โจมตีมี	กลุ่มอาชญากรรมขนาดใหญ่มีเซิร์ฟเวอร์และซอฟต์แวร์เฉพาะ
Opportunity (โอกาส)	ช่องทางหรือจังหวะที่เปิดโอกาสให้การโจมตีสำเร็จ	ช่องโหว่ของระบบ, การตั้งค่าผิด, พฤติกรรมผู้ใช้ที่ขาดการระมัดระวัง

กรอบการวิเคราะห์นี้ถูกใช้ในกระบวนการ **Threat Intelligence** และ **Risk Management** เพื่อประเมินระดับความรุนแรงและความน่าจะเป็นของภัยคุกคาม

1.5.4. สรุปแนวคิด

ภัยคุกคามและผู้ก่อภัยคุกคามเป็นพื้นฐานสำคัญในการทำความเข้าใจโลกของ **Cybersecurity** ภัยคุกคามไม่เพียงแต่เกิดจากซอฟต์แวร์หรือเทคนิคทางคอมพิวเตอร์ แต่ยังเกิดจาก “มนุษย์” ที่มีแรงจูงใจและโอกาสในการโจมตี การระบุประเภทของภัยคุกคามและทำความเข้าใจแรงจูงใจของผู้โจมตีช่วยให้องค์กรสามารถสร้างกลยุทธ์ป้องกันที่เหมาะสม เช่น การใช้ **IDS/IPS**, **Security Awareness Training**, การบังคับใช้นโยบาย **Least Privilege**, และการตรวจสอบระบบอย่างต่อเนื่องด้วย **SIEM**

สุดท้าย นักศึกษาควรตระหนักว่า “การรักษาความปลอดภัยทางไซเบอร์” ไม่ใช่เพียงการป้องกันการโจมตีเท่านั้น แต่คือการเข้าใจภัยคุกคามและผู้โจมตี เพื่อสร้างระบบที่สามารถรับมือ ตอบสนอง และฟื้นฟูจากการ

1.6 การลดภัยคุกคาม ยุทธศาสตร์การป้องกัน และตัวชี้วัดความปลอดภัย (Mitigating Threats, Strategic Defensive Posture, and Security Metrics)

ในระบบความมั่นคงปลอดภัยสารสนเทศ การป้องกันเพียงชั้นเดียวไม่สามารถรับมือกับภัยคุกคามที่ซับซ้อนในยุคดิจิทัลได้อีกต่อไป องค์กรจึงจำเป็นต้องมีแนวทาง “การลดภัยคุกคาม (Threat Mitigation)” ที่ครอบคลุมทุกมิติ ทั้งการป้องกันเชิงเทคนิค การบริหารจัดการนโยบาย และการเตรียมพร้อมตอบสนองเมื่อเกิดเหตุการณ์จริง

การลดภัยคุกคามทำได้โดยการนำ มาตรการควบคุมความปลอดภัย (Security Controls) มาใช้ในรูปแบบที่หลากหลาย เพื่อ ป้องกัน (Prevent), ตรวจจับ (Detect), แก้ไข (Correct) และ ยับยั้ง (Deter) เหตุการณ์ที่อาจส่งผลกระทบต่อข้อมูลและระบบ การออกแบบระบบควบคุมเหล่านี้มักอยู่ภายใต้แนวคิด **Defense-in-Depth** หรือ “การป้องกันแบบหลายชั้น” ที่ผสมผสานการป้องกันทั้งในระดับกายภาพ เทคนิค และกระบวนการ เพื่อเพิ่มความยืดหยุ่นและลดโอกาสที่ภัยคุกคามจะทะลุทะลวงเข้าสู่ระบบสำคัญขององค์กรได้

1.6.1. การควบคุมความปลอดภัยเพื่อป้องกันภัยคุกคาม (Mitigating Threats — Control Classes)

การควบคุมความปลอดภัย (Security Controls) เป็นหัวใจของการจัดการความเสี่ยง (Risk Management) ซึ่งสามารถแบ่งออกได้เป็น 3 ประเภทหลักตามลักษณะการใช้งาน ดังตารางต่อไปนี้

ประเภทของ Control	คำอธิบาย	ตัวอย่างเทคโนโลยี
Physical Controls (การควบคุมเชิงกายภาพ)	ป้องกันการเข้าถึงทางกายภาพของบุคคลหรืออุปกรณ์ที่ไม่ได้รับอนุญาต	Locks, CCTV, Mantrap, ระบบตรวจบัตรเข้าออก (Access Badge)
Technical Controls (การควบคุมเชิงเทคนิค)	ใช้เทคโนโลยีเพื่อจำกัด ตรวจสอบ หรือป้องกันภัยคุกคามโดยอัตโนมัติ	MFA, Encryption, IDS/IPS, Firewalls, Endpoint Protection
Administrative Controls (การควบคุมเชิงบริหารจัดการ)	อ้างอิงนโยบาย ขั้นตอน และการบริหารจัดการบุคลากรเพื่อควบคุมความปลอดภัย	Security Policies, Awareness Training, DRP/BCP, Audit Review

นอกจากนี้ การควบคุมความปลอดภัยยังสามารถจัดประเภทได้ตามหน้าที่ของมันในกระบวนการป้องกันภัยคุกคาม ได้แก่

- Preventive Controls:** การป้องกันไม่ให้เกิดเหตุการณ์เกิดขึ้น เช่น การใช้ MFA, Firewall, การเข้ารหัสข้อมูล (Encryption)
- Detective Controls:** การตรวจจับเหตุการณ์ที่เกิดขึ้นแล้ว เช่น ระบบตรวจจับการบุกรุก (IDS), ระบบจัดการเหตุการณ์ความปลอดภัย (SIEM)
- Corrective Controls:** การแก้ไขผลกระทบจากเหตุการณ์ เช่น การกู้คืนระบบ (Backup & Restore), การติดตั้งแพตช์ (Patch Management)
- Deterrent Controls:** การยับยั้งหรือเตือนภัย เช่น การใช้ป้ายเตือนการบันทึกภาพจากกล้องวงจรปิด หรือระบบแจ้งเตือนผู้บุกรุก
- Compensating Controls:** มาตรการชดเชยเมื่อไม่สามารถใช้การควบคุมหลักได้ เช่น การตรวจสอบด้วยคน (Manual Review) แทนระบบอัตโนมัติ

การใช้มาตรการหลายรูปแบบผสมกันช่วยให้องค์กรสามารถลดความเสี่ยงได้อย่างมีประสิทธิภาพและตอบสนองต่อภัยคุกคามที่เปลี่ยนแปลงอย่างรวดเร็ว

1.6.2. ยุทธศาสตร์เชิงป้องกันขององค์กร (Strategic Defensive Posture)

ยุทธศาสตร์การป้องกันเป็นการกำหนดทิศทางระยะยาวในการรักษาความมั่นคงปลอดภัยขององค์กร โดยมุ่งเน้นทั้งการป้องกันเชิงรุก การตรวจจับเชิงลึก และการตอบสนองต่อเหตุการณ์อย่างมีระบบ

Zero Trust & Identity-First Security

แนวคิด **Zero Trust Architecture (ZTA)** มีหลักการสำคัญคือ “ไม่ไว้วางใจโดยปริยาย (Never Trust, Always Verify)” ซึ่งหมายความว่าผู้ใช้ทุกคนและอุปกรณ์ทุกเครื่องจะต้องผ่านการตรวจสอบตัวตนและสิทธิ์

การเข้าถึงทุกครั้ง ไม่ว่าจะอยู่ภายในหรือภายนอกเครือข่ายองค์กร
ตัวอย่างเทคโนโลยีสำคัญ:

- **Multi-Factor Authentication (MFA)** — เพิ่มชั้นการยืนยันตัวตน
 - **Microsegmentation** — แบ่งเครือข่ายออกเป็นส่วนย่อยเพื่อลดการเคลื่อนไหวยของผู้โจมตี
 - **Continuous Authentication** — ตรวจสอบสิทธิ์อย่างต่อเนื่องขณะใช้งานระบบ
- แนวทางนี้ยังเชื่อมโยงกับ **Identity-First Security** ที่ให้ “ตัวตนของผู้ใช้ (Identity)” เป็นศูนย์กลาง
ของนโยบายความปลอดภัยทุกระดับ

Defense-in-Depth (การป้องกันแบบหลายชั้น)

กลยุทธ์นี้เน้นการวางระบบควบคุมหลายชั้น ในจุดต่าง ๆ ของสถาปัตยกรรม เช่น Firewall สำหรับกรองการ
เชื่อมต่อภายนอก, IDS/IPS สำหรับตรวจจับการบุกรุก, Endpoint Protection สำหรับป้องกันอุปกรณ์ผู้ใช้
และ Awareness Training เพื่อเสริมภูมิคุ้มกันทางพฤติกรรมของบุคลากร แม้การควบคุมชั้นหนึ่งจะล้มเหลว
แต่ชั้นอื่น ๆ ยังคงสามารถทำหน้าที่ป้องกันได้

Supply Chain Security (ความมั่นคงปลอดภัยของห่วงโซ่อุปทาน)

ภัยคุกคามในยุคใหม่มักเกิดจากช่องโหว่ของซอฟต์แวร์หรือฮาร์ดแวร์ในห่วงโซ่อุปทานขององค์กร ดังนั้นจึง
จำเป็นต้องใช้มาตรการตรวจสอบและยืนยันความน่าเชื่อถือของส่วนประกอบทั้งหมด เช่น

- **SBOM (Software Bill of Materials):** รายการส่วนประกอบซอฟต์แวร์ทั้งหมดเพื่อช่วยตรวจสอบช่องโหว่
- **Code Signing:** การลงลายเซ็นดิจิทัลเพื่อรับรองความถูกต้องของซอฟต์แวร์
- **Secrets Management:** การจัดเก็บและควบคุมรหัสลับ เช่น API Keys หรือรหัสผ่านอย่างปลอดภัย

Incident Response / BCP / DR

เมื่อเกิดเหตุการณ์ด้านความปลอดภัย องค์กรต้องสามารถตอบสนองและฟื้นฟูระบบได้อย่างรวดเร็ว โดยมี
กระบวนการที่ชัดเจน เช่น

- **Runbooks:** คู่มือขั้นตอนการตอบสนองต่อเหตุการณ์ (Incident Playbook)
- **Tabletop Drills:** การจำลองสถานการณ์เพื่อทดสอบความพร้อมของทีม
- **Post-incident Review:** การทบทวนและปรับปรุงมาตรการหลังเหตุการณ์จริง เพื่อป้องกันการเกิดซ้ำ

ยุทธศาสตร์เหล่านี้ช่วยให้การรักษาความมั่นคงปลอดภัยมีความต่อเนื่องและยั่งยืนในระยะยาว

1.6.3. ตัวชี้วัดความปลอดภัยสารสนเทศ (Security Metrics)

การวัดผลเป็นขั้นตอนสำคัญในการประเมินประสิทธิภาพของระบบความปลอดภัย โดยตัวชี้วัด (Metrics) ช่วย
ให้องค์กรสามารถระบุจุดแข็ง จุดอ่อน และแนวทางปรับปรุงได้อย่างเป็นรูปธรรม

Metric	ความหมาย	ตัวอย่างการใช้งาน
MTTD (Mean Time to Detect)	ระยะเวลาเฉลี่ยที่ใช้ในการตรวจจับภัยคุกคาม	ใช้ประเมินความเร็วของระบบ IDS/SIEM
MTTR (Mean Time to Respond)	ระยะเวลาเฉลี่ยในการตอบสนองต่อเหตุการณ์	ใช้ประเมินประสิทธิภาพของทีม Incident Response
Patch Latency	ระยะเวลาที่ใช้ในการอัปเดตแพตช์หลังจากพบช่องโหว่	ยิ่งสั้นยิ่งลดความเสี่ยงจากการโจมตี
Backup Health	ความสมบูรณ์และความพร้อมของระบบสำรองข้อมูล	ตรวจสอบได้จากการทดสอบการกู้คืน (Restore Test)
Access Review Rate	อัตราการตรวจสอบสิทธิ์ผู้ใช้ในระบบ	ใช้เพื่อป้องกันสิทธิ์คงค้างของผู้ที่ลาออกหรือเปลี่ยนหน้าที่
Phishing Resilience %	อัตราการต่อต้านอีเมลหลอกลวง	วัดผลจากการจำลองการทดสอบ Phishing ภายในองค์กร
Suspicious Email Reporting Rate	อัตราการรายงานอีเมลต้องสงสัยโดยผู้ใช้	สะท้อนระดับการมีส่วนร่วมและความตื่นตัวของพนักงาน

การติดตาม Metrics เหล่านี้อย่างต่อเนื่องช่วยให้ผู้บริหารสามารถตัดสินใจเชิงกลยุทธ์ได้แม่นยำ เช่น การเพิ่มงบประมาณในส่วนที่ตรวจพบจุดอ่อน หรือการปรับปรุงขั้นตอน Incident Response เพื่อให้ MTTR ลดลง

1.6.4. สรุปแนวคิด

การป้องกันภัยคุกคามที่มีประสิทธิภาพต้องอาศัยทั้ง เครื่องมือควบคุม (Control Classes), ยุทธศาสตร์เชิงป้องกัน (Defensive Posture) และ การวัดผล (Security Metrics)
ทั้งสามส่วนนี้ทำงานร่วมกันในวงจร **Plan → Implement → Monitor → Improve** ซึ่งเป็นแนวทางของ **Continuous Security Improvement**